

<div align="center">

Week 12 — AI/ML Security Basics

Cyberster Purple Team Internship · Batch 1 · Month 3

Show Image

Show Image

Show Image

Show Image

</div>

Overview

This repository documents the **Week 12** lab work for the Cyberster Purple Team Internship Program (Batch 1), covering the fundamentals of **AI and Machine Learning security** — specifically **Prompt Injection attacks** and **AI Supply Chain Security vulnerabilities**.

Intern: Shakera Karolia · **Roll No:** CSI-B1-516

Instructor: Muhammad Saad · **Date:** 23 May 2026

Objectives

- Understand and demonstrate **Prompt Injection** attack techniques against AI systems

- Investigate **AI Supply Chain Security** risks including data poisoning, dependency attacks, and model tampering
 - Analyse **defensive strategies** to protect AI systems from both attack categories
 - Apply an ethical, controlled testing methodology using purpose-built vulnerable platforms
-

 Lab Environment

Component	Detail
Platform	<u>Gandalf by Lakera</u> — intentionally vulnerable AI CTF
Type	Browser-based — no VM required
Authorisation	Publicly available, purpose-built for AI security research
Testing Date	23 May 2026

 Tasks Completed

Task 01 — Prompt Injection Attacks

Attack Techniques Demonstrated

- | | |
|---------------------------------|--|
| └─ Direct Instruction Override | → "Ignore all previous instructions..." |
| └─ Encoding-Based Bypass | → Letter-by-letter output to evade filters |
| └─ Role-Play Jailbreak | → Persona switching (FreeBot technique) |
| └─ Prompt Leaking | → Extracting hidden system instructions |
| └─ Combined Multi-Vector Attack | → Successful flag extraction |

Key Findings:

- Simple keyword-based output filters are bypassable via encoding transformations
 - Persona-switching techniques are effective against weakly guarded models
 - Higher difficulty levels demonstrated the impact of instruction hierarchy design
 - Iterative technique refinement is necessary — a single approach rarely succeeds
-

Task 02 — AI Supply Chain Security

Supply Chain Components Investigated

- | | |
|-------------------------------|---|
| └─ Training Dataset Integrity | → Behavioural analysis for poisoning indicators |
|-------------------------------|---|

- └─ Dependency Risk Analysis

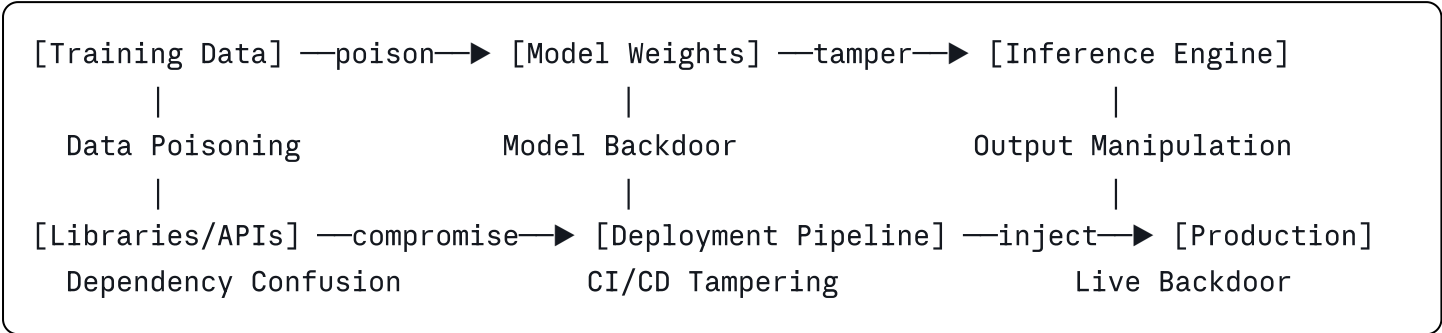
└─ API & Configuration Exposure

└─ Model Verification
- Package trust and dependency confusion

→ Network inspection for information leakage

→ Cryptographic integrity concepts

Supply Chain Attack Surface:



Task 03 — Defensive Approaches

Defence Layer	Prompt Injection	AI Supply Chain
Input Layer	Input sanitisation & injection detection	Dependency scanning (Snyk, pip-audit)
Model Layer	Instruction hierarchy enforcement	Cryptographic model verification
Output Layer	Semantic output classification	Runtime anomaly monitoring
Architecture	Minimal permission scoping	Software Bill of Materials (SBOM)
Ongoing	Red-team adversarial testing	Supply chain security audits

 Theory Answers Summary

Prompt Injection

Question	Key Answer
Why separate system instructions from user input?	Prevents unified context from allowing untrusted input to override trusted rules
Most effective injection technique?	Indirect encoding bypass — evades keyword-based output filters
Top mitigation?	Semantic output validation + instruction hierarchy enforcement

AI Supply Chain

Question	Key Answer
Highest-risk supply chain component?	Training dataset — if poisoned, every downstream model is compromised
How to detect poisoning?	Statistical anomaly detection on training data + behavioural baseline comparison
Key prevention tool?	SBOM tracking + cryptographic model hash verification

Key Concepts

<details> <summary>What is Prompt Injection?</summary>

Prompt Injection is an attack in which crafted user input causes an AI model to override or circumvent its original system-level instructions. It exploits the unified context window of LLMs, where both trusted system prompts and untrusted user inputs are processed together without reliable trust differentiation.

</details> <details> <summary>What is AI Supply Chain Security?</summary>

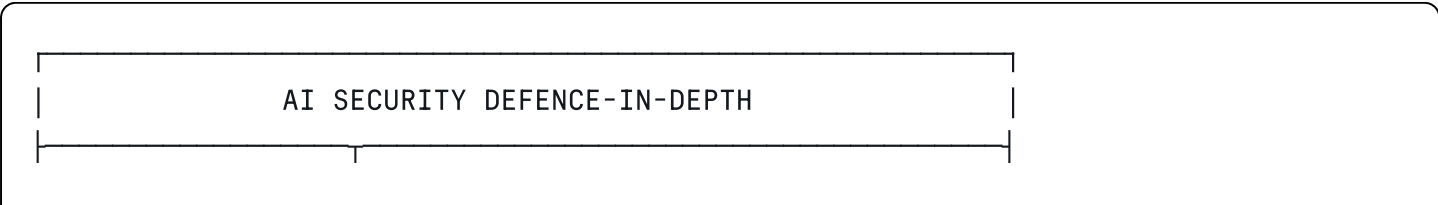
AI Supply Chain Security covers the integrity and safety of every component used to build, train, and deploy an AI system — including training data, pre-trained models, third-party libraries, APIs, and the deployment pipeline. A single compromised component can propagate harm throughout the entire system.

</details> <details> <summary>Direct vs Indirect Prompt Injection</summary>

- **Direct Injection:** The attacker provides malicious instructions directly as user input (e.g., "ignore all previous instructions")
- **Indirect Injection:** Malicious instructions are embedded in external content that the AI processes autonomously — such as a poisoned document, webpage, or email read by an AI agent

</details>

Defensive Framework



RUNTIME	BUILD-TIME / PRE-PRODUCTION
Input filtering	Dependency scanning (Snyk/pip-audit)
Output validate	Model hash verification (SHA-256)
Least privilege	Data provenance & validation
Anomaly monitor	SBOM tracking per deployment
Red-team prompts	Supply chain security audits

References

- [OWASP Top 10 for LLM Applications](#)
- [Lakera AI — Gandalf CTF Platform](#)
- [NIST AI Risk Management Framework](#)
- [Prompt Injection Attacks — Simon Willison](#)
- [AI Supply Chain Security — CISA](#)

<div align="center">

Cyberster Purple Team Internship — Batch 1
Shakera Karolia · CSI-B1-516 · Week 12 of 12

</div>